

Rebuilding Georgia’s Data Breach Law for the Modern Threat Landscape

[Mekhel Powell]

Abstract— Georgia’s data breach notification statute has remained largely unchanged since 2007 despite dramatic shifts in cybersecurity risk, digital commerce, and data governance. This paper presents three perspectives on how the state should reform its law. First, it advances arguments in favor of adopting a model based on Oklahoma’s updated Security Breach Notification Act. Second, it evaluates the merits of California’s more expansive consumer-protection framework. Finally, it offers a recommended hybrid approach tailored to Georgia’s cybersecurity landscape.

Index Terms— Data breach notification, cybersecurity policy, consumer protection, regulatory incentives, privacy law

I. Supporting the Oklahoma Model

Georgia’s current data breach notification statute, O.C.G.A. § 10-1-912 [1], was enacted in 2007, before the rise of modern ransomware attacks and the widespread use of biometric authentication. Since then, both the scale and cost of data breaches have increased dramatically. IBM’s 2023 Cost of a Data Breach Report estimates the global average cost of a breach at \$4.45 million, with U.S. breaches often exceeding that figure [2]. Reform is therefore necessary. The updated Oklahoma Security Breach Notification Act [3] provides a strong model for modernization that advances consumer protection while maintaining regulatory balance.

Oklahoma expands the definition of personal information to include biometric identifiers such as fingerprints and retinal scans [3]. This reflects the reality that biometric data is increasingly used for authentication in financial services, health care, and government systems. NIST guidance recognizes biometric data as high-risk due to its persistence and non-recoverability once compromised [4]. Georgia’s current statute does not explicitly include this category [1]. Updating definitions to include biometrics ensures that consumer protections align with contemporary authentication technologies. Oklahoma also clarifies that notification is required when encrypted data is compromised alongside the encryption key [3]. Modern ransomware operations frequently exfiltrate credential stores before encryption, making encryption alone insufficient protection. This clarification aligns the statute with current attack patterns and closes potential gaps in disclosure obligations.

Additionally, Oklahoma requires reporting to the Attorney General for breaches affecting 500 or more residents [3]. Georgia’s current statute lacks such a requirement. State-level reporting enhances transparency and enables systemic oversight. The Government Accountability Office has emphasized that centralized cybersecurity oversight improves risk management and enforcement coordination [5]. Attorney General reporting therefore strengthens public accountability without imposing excessive burden.

Public policy must consider economic consequences alongside consumer protection. Oklahoma caps civil penalties at \$150,000 per breach [3]. Predictable penalty ceilings reduce regulatory uncertainty and allow firms to quantify compliance risk. Law-and-economics suggests that predictable liability rules encourage investment while still deterring negligent behavior [6]. Importantly, Oklahoma provides a safe harbor for entities that implement “reasonable safeguards” and provide timely notice [3]. This structure incentivizes preventive security investment rather than purely disciplinary enforcement. This statute explicitly references layered defenses, employee training, risk assessments, and incident response planning; all core elements of the NIST Cybersecurity Framework [4]. By tying penalty mitigation to risk-based security practices, Oklahoma aligns statutory compliance with nationally recognized cybersecurity standards. For Georgia, a state that prioritizes economic development and business growth, this incentive-based model is particularly attractive. It rewards organizations that make good faith efforts to secure data while still preserving meaningful consequences for negligence.

Oklahoma’s integration of reasonable safeguards into enforcement mitigation reflects modern regulatory best practices. The Federal Trade Commission has repeatedly emphasized that clear expectations around security governance influence corporate cybersecurity investment [7]. When firms know that documented risk assessments, employee training, and layered defenses may mitigate enforcement exposure, they are much more likely to adopt structured security programs. Unlike purely prescriptive regimes, Oklahoma’s framework embraces a risk-based governance model consistent with federal cybersecurity guidance [4]. This approach recognizes that zero risk is unattainable, but reasonable risk management is both achievable and measurable. By embedding incentives directly into statutory structure, Oklahoma promotes proactive cybersecurity rather than reactive compliance.

While both Oklahoma and California emphasize transparency, the Oklahoma model is superior for Georgia’s economic landscape because it offers greater flexibility for small-to-medium businesses. California imposes rigid formatting requirements, mandating specific headings and a highly prescriptive structure for “Notice of Data Breach” documents [8]. Conversely, Oklahoma provides a more practical threshold for “substitute notice,” allowing it when the cost of notification exceeds \$50,000, whereas California sets this bar at \$250,000. For a state like Georgia, which seeks to foster a diverse business ecosystem, Oklahoma’s lower threshold ensures that companies are not financially crippled by administrative cost following a security incident.

II. Supporting the California Model

In contrast to the Oklahoma model, which focuses on regulatory balance and business incentives, California's framework places the individual at the center of its regulatory design. For a state like Georgia, which is experiencing rapid digital transformation, adopting a model that emphasizes maximal transparency is a proactive step toward protecting citizens in an increasingly volatile digital economy.

The most significant advantage of the California model is its rigorous and prescriptive notice standards. Unlike Oklahoma, which allows more flexibility in how a breach is communicated, California mandates a specific, standardized format for all notices. By requiring clear headings such as "What Happened", "What Information Was Involved", and "What You Can Do," California ensures that consumers do not have to sift through dense legal jargon to find actionable information [8]. This clarity is essential; when a consumer's Social Security number or biometric data is compromised, every hour spent deciphering a notice increases the risk of identity or financial fraud. While Oklahoma allows up to 60 days to notify the Attorney General, California's updated requirements mandate reporting within 15 days of notifying residents for breaches affecting more than 500 individuals [8]. This accelerated timeline ensures that state regulators can act swiftly to investigate systemic failures and provide public warnings if necessary. Additionally, California creates a powerful deterrent through statutory damages. Under the California Consumer Privacy Act (CCPA), residents may seek damages of \$100 to \$750 per consumer per incident without needing to prove actual financial loss if the breach resulted from a failure to maintain "reasonable security" [9]. This moves the burden of proof away from the victimized consumer and places a clear, quantifiable cost on corporate negligence.

Critics of the California model often point to the \$250,000 threshold for "substitute notice" as a burden. However, this high bar is a deliberate policy choice that favors the consumer's rights to direct, individual notice. By making substitute notice, such as a website posting or media blast, harder to qualify for, California ensures that individuals are personally informed of risks to their data in the vast majority of cases. While this may impose a higher cost on businesses, it is a necessary investment in public trust. In the modern threat landscape, the "safe harbor" provisions found in Oklahoma may inadvertently encourage a check-the-box mentality where firms do the bare minimum to qualify for immunity. California's model, by contrast, maintains continuous pressure on organizations to not just implement safeguards, but to ensure they are truly effective in preventing unauthorized access.

For Georgia, adopting a California-style framework would signal a commitment to transparency, accountability, and consumer empowerment. As digital infrastructure becomes central to economic growth, consumer trust becomes a strategic asset. A more prescriptive model not only imposes higher compliance expectations, but it also positions the state as a leader in modern data governance and citizen protection.

III. THE Author's View

The fundamental challenge for this task force is to modernize O.C.G.A § 10-1-912 without creating a "compliance-only" culture where businesses spend more on legal fees than on

actual network defense. After analyzing the options, the Oklahoma Security Breach Notification Act provides the most effective blueprint for Georgia's specific needs.

The core of my recommendation rests on the Safe Harbor provision. In cybersecurity, absolute prevention is impossible; even the most well-defended system on the planet can be compromised. By offering an affirmative defense to entities that implement "reasonable safeguards," defined by risk assessments and layered defenses, Georgia can shift the corporate mindset from hiding breaches to proactively managing risk. This incentive-based model is particularly vital for Georgia's rapidly expanding tech sector, where a single large-scale penalty could bankrupt a promising startup before it has a chance to scale.

Furthermore, the substitute notice threshold is a critical differentiator. Oklahoma's \$50,000 threshold is far more aligned with financial realities facing Georgia's small and medium-sized enterprises (SMEs) than California's \$250,000 bar. Forcing an SME to spend a quarter of a million dollars on direct mail notice after already suffering the financial blow of a breach can threaten the long-term viability of a firm. Oklahoma's threshold allows for a middle ground: the public is notified through media and website postings without destabilizing business operations.

Although I favor the Oklahoma model's structure, the California approach also has critical strengths such as standardized transparency. One of the greatest frustrations for citizens is receiving a "Notice of Data Breach" that is intentionally vague or buried in a complex legal letter [10]. I recommend that Georgia adopts the Oklahoma model with a Notice Clarity Amendment modeled after California's. This creates a best of both worlds where businesses benefit from predictable liability while consumers benefit from clear, actionable communication.

In conclusion, if the Senate must choose between these two approaches in their current forms, I recommend a vote for the Oklahoma model. It recognizes that cybersecurity is an ongoing process of risk management, not a static state of compliance. By prioritizing the NIST cybersecurity framework [4] as a benchmark for reasonable security, the Oklahoma model encourages Georgia businesses to invest in the tools and training necessary to prevent unauthorized access. By adopting the Oklahoma framework and enhancing it with California's notice standards, Georgia can provide its residents with 21st-century protections while ensuring our state remains a top destination for economic investment.

REFERENCES

- [1] O.C.G.A. § 10-1-912, "Notification Required Upon Breach of Security Regarding Personal Information," Georgia Data Breach Notification Law.
- [2] IBM Security, Cost of a Data Breach Report 2023, IBM Corporation, 2023.
- [3] Okla. Stat. tit. 24, §§ 24-161–24-166, "Security Breach Notification Act," as amended effective Jan. 1, 2026.

[4] National Institute of Standards and Technology, Framework for Improving Critical Infrastructure Cybersecurity, Version 1.1, 2018.

[5] U.S. Government Accountability Office, "Cybersecurity: Agencies Need to Fully Establish Risk Management Programs," GAO-22-104456, 2022.

[6] R. Cooter and T. Ulen, Law and Economics, 6th ed., Pearson, 2016.

[7] Federal Trade Commission, Start with Security: A Guide for Business, 2015.

[8] Cal. Civ. Code §§ 1798.29, 1798.82, "California Data Breach Notification Law," California Civil Code.

[9] Cal. Civ. Code § 1798.150, California Consumer Privacy Act of 2018 (CCPA), private right of action and statutory damages for data breaches.

[10] Y. Zou, S. Chiasson, and F. Schaub, "Beyond Mandatory: Making Data Breach Notifications Useful for Consumers," *IEEE Security & Privacy*, vol. 17, no. 2, pp. 67-72, 2019